



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Fortinet FortiSandbox Command Injection Exploitation Cluster CVE-2026-25089 and CVE-2026-39808

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-20
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Fortinet FortiSandbox Command Injection Exploitation Cluster CVE-2026-25089 and CVE-2026-39808 -
CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-20 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Fortinet FortiSandbox Command Injection Exploitation Cluster

CVE-2026-25089 and CVE-2026-39808

1. Executive Summary

CISA KEV additions and public reporting identify Fortinet FortiSandbox command-injection vulnerabilities as exploited. Because sandbox appliances often inspect untrusted content and sit near sensitive security workflows, defenders should treat exposed or unpatched FortiSandbox systems as high-priority assets for patching, log review, and segmentation validation.

Lost Boys Cyber selected this vulnerability for the 2026-07-20 UTC daily production run because public reporting indicates active exploitation or urgent exposure, credible government/vendor corroboration, and near-term defender actionability. This report avoids exploit-step reproduction and focuses on prioritization, validation, detection, and response.

Field	Assessment
Report family	CVE / Vulnerability Threat Intelligence Report
Daily section	Top 2 vulnerabilities
CVE(s)	CVE-2026-25089, CVE-2026-39808
Severity	Critical
Confidence	High
Published / processed	2026-07-20 UTC
Hard IOCs	None confirmed in reviewed public sources
Primary defender question	Are exposed affected assets patched, isolated, or monitored for exploitation and post-compromise behavior?

2. Vulnerability Metadata

Field	Value
Affected product / technology	Fortinet FortiSandbox
Vulnerability class	OS command injection / crafted HTTP request command execution
Exploitation status	CISA KEV 2026-07-16; public reporting describes exploitation in attacks
Initial access relevance	High where internet-facing or externally reachable
Patch priority	Emergency for exposed systems; accelerated for internal systems with elevated trust

3. Source Review & Confidence

Source	URL	Analyst Use
CISA KEV JSON	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	Authoritative exploited-status and due-date source.
CISA alert: Adds Three KEVs	https://www.cisa.gov/news-events/alerts/2026/07/16/cisa-adds-three-known-	Government alert context for July 16 KEV

	exploited-vulnerabilities-catalog	additions.
NVD CVE-2026-25089 detail	https://nvd.nist.gov/vuln/detail/CVE-2026-25089	CVE metadata cross-check.
Qualys ThreatPROTECT	https://threatprotect.qualys.com/2026/06/17/fortinet-fortisandbox-vulnerability-exploited-by-attackers-cve-2026-39808-cve-2026-25089-cve-2026-39813/	Vulnerability-management context.
Cybersecurity News coverage	https://cybersecuritynews.com/fortisandbox-vulnerabilities-exploited/	Secondary public reporting on exploitation mechanics.

At least three public sources were reviewed where available, prioritizing government, vendor, NVD/CVE, and reputable security research. Source selection expanded to the last seven days where necessary because not every high-priority vulnerability receives three separate primary writeups within 24 hours.

4. Vulnerability Details

CVE-2026-25089 and CVE-2026-39808 are described in CISA KEV as Fortinet FortiSandbox OS command-injection vulnerabilities. Public reporting says crafted HTTP requests may allow unauthenticated command execution. Defenders should verify appliance build levels, management exposure, and unexpected process/network activity around the appliance.

Attack Surface	Defender Relevance	Immediate Validation
Internet-facing services	Exploitation can precede normal patch windows.	Confirm exposure through asset inventory, EASM, and firewall/reverse-proxy logs.
Auth boundaries	Many exploited flaws bypass or weaken expected access control.	Validate MFA, service-account privilege, and anomalous authentication events.
Post-exploitation tooling	Public-facing exploitation often transitions to script execution, web shells, or data staging.	Review EDR process telemetry and web/app logs for command execution indicators.

5. Attack Scenarios

Scenario	Preconditions	Defensive Breakpoints
Opportunistic internet exploitation	Exposed affected service remains unpatched.	EASM validation, emergency patching, WAF/virtual patch, isolation.
Targeted follow-on intrusion	Attacker obtains code execution or privileged function access.	EDR command telemetry, account monitoring, segmentation.
Third-party managed exposure	Vendor-managed or supplier-hosted affected system is reachable.	Supplier evidence request, access-log review, incident-notification SLA.

6. Threat Landscape & Exploitation Status

Public KEV or exploitation reporting means defenders should assume scanning and copycat activity can occur rapidly. Prioritize confirmation of asset ownership, patch state, and evidence of anomalous access before closing tickets as simply patched.

7. Affected Products and Exposure

Exposure Area	Why It Matters	Immediate Check
---------------	----------------	-----------------

Production application servers	Highest business and data impact if compromised.	Confirm exact version/build and compensating controls.
Test or staging servers	Often less monitored but trusted by production workflows.	Inventory externally reachable non-production systems.
Identity-integrated services	Compromise can enable valid-account abuse.	Review service principals, OAuth grants, privileged role changes.

8. Mitigation and Workarounds

Priority	Action	Owner
0-24 hours	Patch or remove internet exposure for affected systems.	Platform / Vulnerability Management
0-24 hours	Preserve logs before rotation and review for exploitation attempts.	SOC / IR
24-72 hours	Run behavior hunts below and investigate outliers.	Threat Hunting
This week	Validate supplier and managed-service coverage.	Risk / Vendor Management

9. Detection Engineering

Signal	Telemetry Source	Analytic Goal
Exploit-related keywords: CVE-2026-25089, CVE-2026-39808, FortiSandbox, command injection, Fortinet	Web, proxy, EDR, SIEM	Surface scanning, exploit attempts, or incident notes.
Scripting launched by service or web worker accounts	EDR process telemetry	Detect exploitation-to-command execution transition.
New files in web/app writable directories	EDR/file integrity	Detect web shell or payload staging.

```

title: Lost Boys Cyber - Fortinet FortiSandbox Command Injection Exploitation Cluster CVE-2026-25089
and CVE-2026-39808
id: lbc-fortinet-fortisandbox-command-injection-exploitati
status: experimental
description: Behavioral scaffold for exploitation or post-exploitation activity associated with
CVE-2026-25089, CVE-2026-39808.
logsource:
  product: windows
  category: process_creation
detection:
  selection_service_shell:
    ParentImage|contains:
      - 'w3wp.exe'
      - 'tomcat'
      - 'httpd'
      - 'nginx'
      - 'java.exe'
    Image|endswith:
      - '\cmd.exe'

```

```

- '\powershell.exe'
- '\cscript.exe'
- '\wscript.exe'
selection_keywords:
  CommandLine|contains:
    - "CVE-2026-25089"
    - "CVE-2026-39808"
    - "FortiSandbox"
    - "command injection"
    - "Fortinet"
condition: selection_service_shell or selection_keywords
fields:
- UtcTime
- Image
- ParentImage
- CommandLine
- User
falsepositives:
- Authorized administration and vulnerability validation
level: high

```

10. Threat Hunting

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where ProcessCommandLine has_any ('CVE-2026-25089', 'CVE-2026-39808', 'FortiSandbox', 'command
injection', 'Fortinet')
  or (InitiatingProcessFileName in~ ("w3wp.exe", "java.exe", "httpd.exe", "nginx.exe") and FileName
in~ ("cmd.exe", "powershell.exe", "cscript.exe", "wscript.exe", "python.exe"))
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine
| order by Timestamp desc

DeviceFileEvents
| where Timestamp > ago(14d)
| where FolderPath has_any ("inetpub", "wwwroot", "tomcat", "sharepoint", "fortinet", "oracle")
| where ActionType in ("FileCreated", "FileModified")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Files=make_set(FolderPath, 20) by
DeviceName, InitiatingProcessAccountName

```

11. MITRE ATT&CK Mapping

Technique	Relevance
T1190 Exploit Public-Facing Application	Primary initial-access pattern for exposed systems.
T1059 Command and Scripting Interpreter	Expected post-exploitation tradecraft.
T1105 Ingress Tool Transfer	Plausible payload staging after code execution.
T1041 Exfiltration Over C2 Channel	Relevant where compromise reaches sensitive data.

12. Validation / Lab Testing

No exploit reproduction was performed in this automated report run. Validation should be limited to authorized version checks, vendor guidance, patch verification, and benign telemetry review.

13. Recommended Actions Summary

Rank	Action	Evidence to Retain
1	Identify affected assets and patch/isolate them.	Asset list, version output, change ticket.
2	Review logs for pre-patch exploitation.	Web, identity, EDR, and firewall excerpts.

3	Run hunts and escalate confirmed anomalies.	Query output and case notes.
4	Re-check managed and supplier-hosted systems.	Supplier attestation and support ticket.

14. References

- [1] CISA KEV JSON: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [2] CISA alert: Adds Three KEVs: <https://www.cisa.gov/news-events/alerts/2026/07/16/cisa-adds-three-known-exploited-vulnerabilities-catalog>
- [3] NVD CVE-2026-25089 detail: <https://nvd.nist.gov/vuln/detail/CVE-2026-25089>
- [4] Qualys ThreatPROTECT: <https://threatprotect.qualys.com/2026/06/17/fortinet-fortisandbox-vulnerability-exploited-by-attackers-cve-2026-39808-cve-2026-25089-cve-2026-39813/>
- [5] Cybersecurity News coverage: <https://cybersecuritynews.com/fortisandbox-vulnerabilities-exploited/>